第2章 加密和认证

信息系统安全模型

通信安全模型

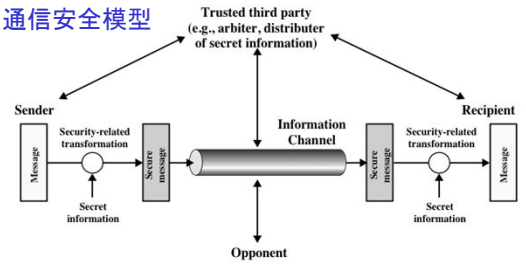


Figure 1.5 Model for Network Security

访问控制模型

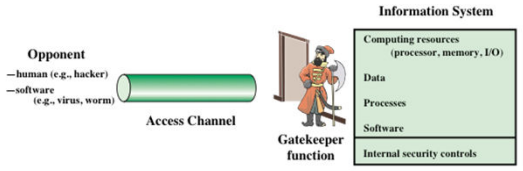
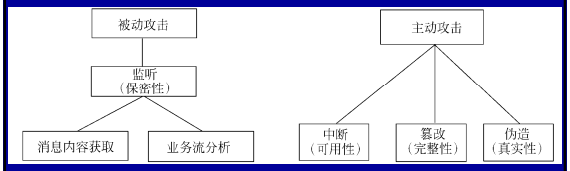


Figure 1.6 Network Access Security Model

© 2017 Pearson Education, Inc., Hoboken, NJ. All rights reserved.

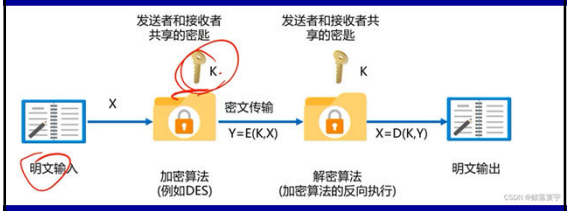
信息安全威胁



安全性的目标和威胁、防御技术

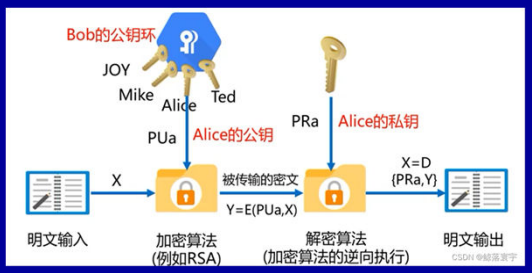
目标	威胁	防御技术
数据机密性	数据暴露	对称加密、公钥加密、随机数、……
数据完整性	数据篡改	公钥加密
不可否认性	抵赖	数字签名
鉴别	确认身份	数字证书
系统可用性	拒绝服务	Firewall、IDS、Antivirus
审计	数据活动可被跟踪	日志

对称加密算法



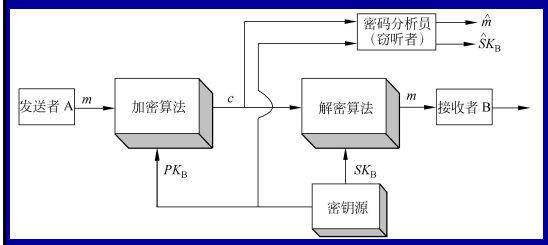
- 加密和解密密钥一样，典型算法有DES、AES、RC4
- 强加密算法，安全取决于密钥的保密性而非算法的保密性
- 密钥管理和分发难

非对称加密算法

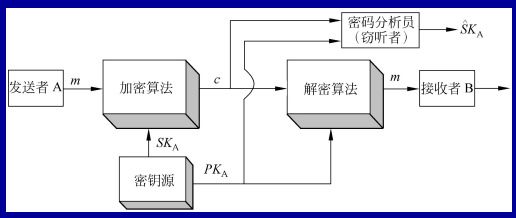


解决了不安全信道密钥分发问题

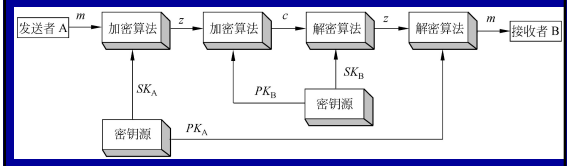
公钥体制加密的框图



公钥体制认证的框图

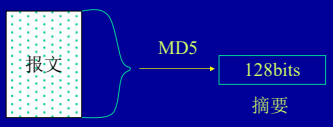


公钥体制认证保密的框图



散列函数（消息摘要）

- **哈希算法/Hash：常用算法MD5、SHA**
- **将一段任意长度的数据转换为一段定长的数据**



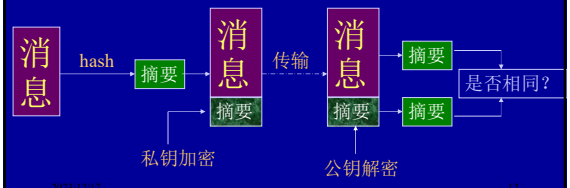
https://www.fileformat.info/tool/hash.htm

特点：

- **不可逆性：无法通过Hash结果推导出原文**
- **无碰撞性：几乎不可能找到x和y的Hash是一样的**
- **雪崩效应：输入轻微变化，Hash输出值巨大变化**

数字签名

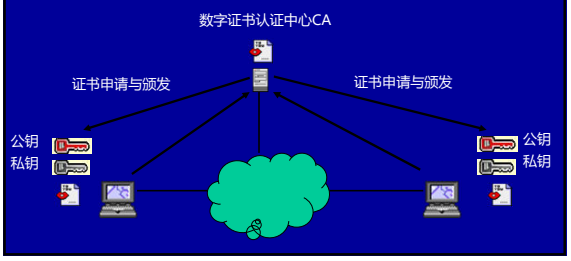
- 对消息的摘要用私钥进行加密。消息接收者用公钥解密摘要，验证发送者身份。
- 如果传输前后消息摘要相同，说明消息是完整的，未被篡改。



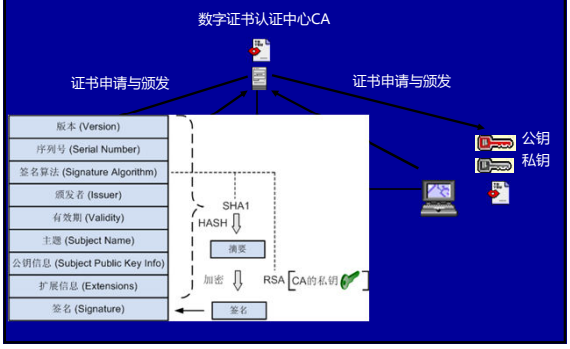
数字证书的工作原理

数字证书（Digital Certificate，类似身份证的作用）
CA（Certificate Authority，电子商务认证授权机构）

数字证书	
姓名，地址，组织	所有者公钥
证书有效期	认证机构数据签名



数字证书的工作原理



密码算法的安全性

- **无条件安全**
  - 无论破译者有多少密文,也无法解出对应的明文。**除了“一次一密”任何密码算法都是可破译的**
- **计算上安全**
  - 破译的代价超出信息本身的价值
  - 破译的时间超出了信息的有效期

密码分析

攻击类型	密码破译者的已知信息
唯密文	• 加密算法，要解密的密文
已知明文	• 加密算法 • 要解密的密文 • 一个或多个用密钥产生的明文、密文对
选择明文	• 加密算法 • 要解密的密文 • 破译者选定的明文信息，以及使用密钥产生对应的密文
选择密文	• 加密算法 • 要解密的密文 • 破译者选定的密文，以及使用密钥产生对应的解密密文
选择文本	• 加密算法 • 要解密的密文 • 破译者选定的明文信息，以及使用密钥产生对应的密文 • 破译者选定的密文，以及使用密钥产生对应的解密明文

量子通信

- 量子是光子、电子等微观粒子;
- 量子态无法克隆，其信道不可能被窃听；
- 量子信道主要用于密钥的传送;
- 合法接收方必须知道发送方量子的偏振态（调制信息）。

太空量子通信设施

量子电话

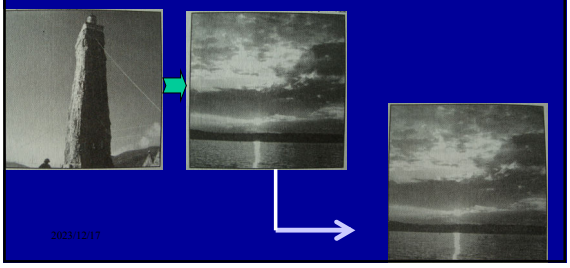
信息的隐蔽技术

- 信息隐藏技术
  - 隐蔽通信
  - 版权保护
  - 内容认证

隐藏在图象中 ← 最低有效位等
隐藏在视频中 ← 视觉不敏感区域
隐藏在语音中 ← 语音频谱相位等
隐藏在文本中 ← 文字位置等
……

信息隐藏

一幅图片隐藏到另一幅图片中：



认证技术

发信者身份认证：消息来自哪一个人？

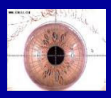
口令

IC卡

USBkey数字证书

指纹500kbits

脸形？



虹膜256字节

声纹48bit

消息来源认证：消息来自哪台设备？

- 射频指纹

- 设备身份：
  USBkey、IC卡、IP、MAC地址等

认证协议

用来安全地建立双方的信任。

- 单向认证协议：“提问”→“响应”，两个消息流。用于一方信任另一方，如移动通信基站对移动终端的认证
- 双向认证协议：“提问”→“响应、提问”→“响应”，三个消息流。
  用于双方彼此互不信任。常用于端到端通信。

典型双向认证协议

A　　B

A, B, N_a　　你是B吗？ →

← B, A, N_b, $MAC_{ka}(N_a, N_b, B)$　　是的，你是A吗？

A, B, $MAC_{ab}(N_a, N_b)$　　我是A! →

加密的摘要或数字签名